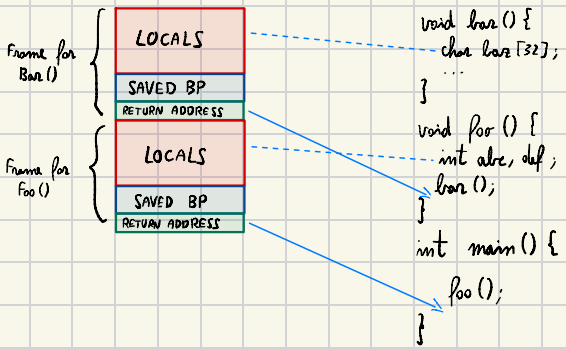
PWN Shellcode

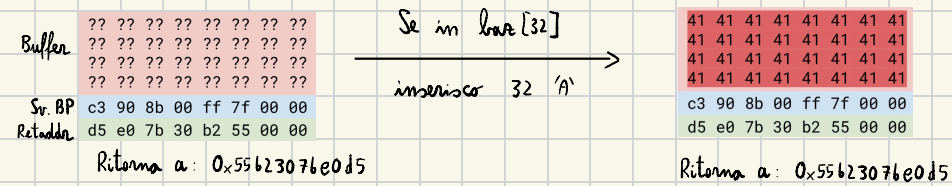


Stack Overflows

Lo stack contiene informazioni che tengono traccia del control flow di un programma. Sovrascrivere un buffer situato nello stack, può permetterci di dirottare il flusso di esecuzione verso qualsiasi punto desideriamo.



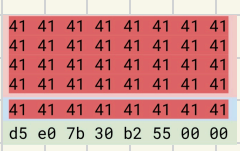
Nel caso di bar() lo stack è composto così:



Ritorna a: 0x55623076e0d5

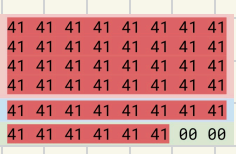
Ritorna a: 0x55623076e0d5

Se provo a scrivere 40 Byte:



Ret: 0x55623076e0d5

Se provo a scrivere 46 Byte:



Ret: 0x414141414141

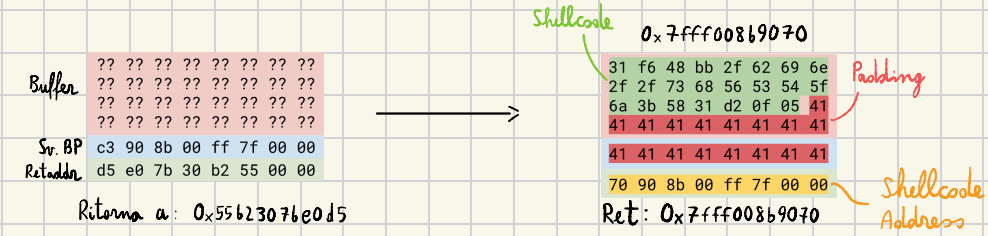
Nel caso dei 46 Byte scritti nel buffer da 32, si riesce a sovrascrivere i valori dell' Instruction Pointer (IP)

=> Posso decidere a che punto far riprendere il programma al termine della funzione

Shellcode

A volte non esiste una funzione "magica" a cui possiamo ritornare, quindi

possiamo injectare il nostro codice nel processo.
Questo codice si chiama Shellcode perché solitamente apre una shell



Mitigation

- **Stack Canaries**
  - viene aggiunto un valore segreto (canary) nello stack tra le variabili locali e il return address, se questo canary è cambiato in seguito ad una overflow injection avviene un crash diretto.

  - Bypass: leggere il valore canary e riscriverlo; Bruteforce (solo in fork server)

- **Address Space Layout Randomization (ASLR)**
  - Randomizza gli indirizzi di: Stack, Heap, Librerie, Codice in modo da non sapere dove si trova il codice.

  - Bypass: · Info Leak: scopire un indirizzo valido
    · Partial Overwrite: controllare solo i byte meno significativi
    · Bruteforce: solo se il target riparte molte volte

- **Write ⊕ Execute (W⊕X, NX, DEP)**
  - una memoria può essere eseguibile o scrivibile, ma non entrambe. La code injection non funziona più perché lo stack non è eseguibile

  - Bypass: · ROP (Return-Oriented Programming);
    · Si riutilizza codice già esistente e lecito.

- Control Flow Integrity (CFI)
  - Limita i salti del flusso di controllo solo verso destinazioni valide previste dal programma. Anche controllando un "RET" non si può saltare ovunque.

  - Bypass: Tecniche avanzate di code reuse (COOP, JOP complessi)